

자체 모의해킹 결과 보고서

포트 스캔 및 웹 애플리케이션 취약점 점검 (nmap / Nikto)

문서번호	PT-2026-0706-01	작성일	2026-07-06
점검 범위	172.16.60.0/24 내 자체 소유 인프라 (queue-gate, web-lb, was-01)	점검자	최시은
점검 도구	nmap 7.99, Nikto 2.6.0 (macOS, Homebrew 설치)	버전	1.0

1. 개요 및 범위

본 점검은 설계·구현한 방화벽 정책과 웹 서버 설정이 실제 환경에서 의도대로 동작하는지 공격자 관점에서 검증하기 위해 수행했다. 점검 대상은 본인이 소유하고 격리된 가상 네트워크(172.16.60.0/24) 내 서버로 한정했으며, 인터넷상의 제3자 시스템이나 프로덕션 환경에는 어떠한 도구도 사용하지 않았다.

본 점검은 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제48조에 따라 자기 소유의 격리된 학습 환경에 한해서만 수행했으며, 외부 시스템에는 적용하지 않았다.

2. 점검 방법론

단계	목표	도구	비고
A	정찰 — 열린 포트 및 서비스 확인	nmap	수행 완료
B	웹 취약점 자동 스캔	Nikto	수행 완료
C	인증 무차별 대입 방어 확인	Hydra	보류 — 로그인 API 백엔드 미구현
D	SQLi/XSS 검증	sqlmap, 수동 페이로드	보류 — 파라미터 기반 엔드포인트 부재

3. 정찰 결과 (nmap)

외부(백목, 172.16.60.1)에서 3개 서버의 주요 6개 포트(22, 80, 443, 3000, 3306, 6379)를 대상으로 스캔했다. 전체 포트(-p-) 스캔은 방화벽이 닫힌 포트에 응답을 반환하지 않아 완료까지 과도한 시간이 소요되어(예상 7시간 이상), 주요 포트 지정 방식(-Pn -p 22,80,443,3000,3306,6379)으로 전환했다.

```
$ nmap -Pn -p 22,80,443,3000,3306,6379 172.16.60.146 # queue-gate
PORT      STATE SERVICE
22/tcp    filtered ssh
80/tcp    open  http
443/tcp    closed https
3000/tcp   filtered ppp
3306/tcp   filtered mysql
6379/tcp   filtered redis

$ nmap -Pn -p 22,80,443,3000,3306,6379 172.16.60.147 # web-lb
PORT      STATE SERVICE
22/tcp    filtered ssh
80/tcp    filtered http
443/tcp    filtered https
3000/tcp   filtered ppp
3306/tcp   filtered mysql
6379/tcp   filtered redis

$ nmap -Pn -p 22,80,443,3000,3306,6379 172.16.60.145 # was-01
PORT      STATE SERVICE
22/tcp    filtered ssh
80/tcp    filtered http
443/tcp    filtered https
3000/tcp   filtered ppp
3306/tcp   filtered mysql
6379/tcp   filtered redis
```

서버	22	80	443	3000	3306 / 6379
queue-gate (공개 진입점)	filtered	open	closed	filtered	filtered
web-lb	filtered	filtered	filtered	filtered	filtered
was-01	filtered	filtered	filtered	filtered	filtered

판정: queue-gate는 설계상 공개 진입점이므로 80번만 open인 것이 정상이다. web-lb와 was-01은 queue-gate 또는 web-lb를 거치지 않은 출발지에게 전 포트가 filtered로 관측되어야 하며, 실제 결과가 이와 일치했다. 443이 closed로 나온 것은 TLS 인증서를 아직 적용하지 않았기 때문이며 별도 결함은 아니다.

4. 웹 취약점 스캔 결과 (Nikto)

공개 진입점인 queue-gate(172.16.60.146)를 대상으로 Nikto 스캔을 2회(조치 전/후) 수행했다.

```
$ nikto -h http://172.16.60.146

+ Server: nginx/1.28.3 (Ubuntu)
+ [013587] /: Suggested security header missing: permissions-policy
+ [013587] /: Suggested security header missing: strict-transport-security
+ [013587] /: Suggested security header missing: x-content-type-options
+ [013587] /: Suggested security header missing: referrer-policy
+ [013587] /: Suggested security header missing: content-security-policy
+ 8229 requests: 0 errors and 22 items reported on the remote host
```

보안 헤더 관련 5개 항목 외에, Nikto가 함께 보고한 Vignette·Cisco·FrontPage·CCBill 관련 다수 항목은 범용 취약점 데이터베이스를 기계적으로 대조한 결과로, 현재 스택(Nginx 정적 서버 + Node.js API)과 무관한 오탐(false positive)으로 판단하여 조치 대상에서 제외했다.

4.1 조치

```
sudo vi /etc/nginx/conf.d/queue.conf
# location / { 블록 위에 다음 지시어 추가
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=()" always;
add_header Content-Security-Policy "default-src 'self'" always;

sudo nginx -t
sudo systemctl restart nginx
```

4.2 재검증 결과

```
$ nikto -h http://172.16.60.146

+ [013587] /: Suggested security header missing: strict-transport-security
+ (permissions-policy, referrer-policy, content-security-policy 항목 미보고 - 조치 확인)
+ 8229 requests: 0 errors and 20 items reported on the remote host
```

항목	1차	조치 후	비고
Content-Security-Policy 누락	미적용	적용됨	해결
Referrer-Policy 누락	미적용	적용됨	해결
Permissions-Policy 누락	미적용	적용됨	해결
Strict-Transport-Security 누락	미적용	미적용	미조치 — TLS 미적용 상태와 연관
X-Content-Type-Options 누락	미적용	미적용	미조치 — 조치 명령 누락 확인, 재조치 필요

5. 잔여 위험 및 권고 사항

- HSTS 헤더 미적용** — TLS 인증서 발급 후 Strict-Transport-Security 헤더를 함께 적용해야 한다. 현재 443 포트가 closed 상태이므로 우선 인증서 적용이 선행되어야 한다.
- X-Content-Type-Options 미적용** — 2차 조치 시 해당 지시어가 실제로는 반영되지 않았다. Nginx 설정 파일을 재확인하고 재조치 후 3차 검증이 필요하다.
- Hydra / sqlmap 미수행** — 로그인 API가 아직 백엔드에 연동되지 않아 유의미한 테스트 대상이 없었다. 회원 인증 API 구현 이후 재점검이 필요하다.

6. 결론

외부 관점에서의 포트 스캔 결과는 설계한 방화벽 정책(2.4 방화벽 매트릭스)과 정확히 일치했으며, 최소권한 원칙이 실제로 구현되어 있음을 확인했다. 웹 취약점 스캔에서 발견한 보안 헤더 누락 5건 중 3건은 즉시 조치했고, 나머지 2건은 TLS 적용과 함께 후속 조치가 필요한 항목으로 남겼다.

작성: 최시은

검토: -

배포: 내부 참고용